

1

Active Directory Attack Techniques -- Explained Simply

A beginner-friendly breakdown of 7 core attacks that target Active Directory's authentication layer, with plain-language explanations and analogies for each.

AGENDA:

1. Password Spraying
2. AS-REP Roasting
3. Kerberoasting
4. Pass-the-Hash (PtH)
5. Pass-the-Ticket (PtT)
6. Silver Ticket
7. Golden Ticket



2

1. PASSWORD SPRAYING

CONCEPT

Instead of trying many passwords against one user, which quickly triggers an account lockout, an attacker tries one single password, such as Summer2026! against every user in the company.

WHY IT WORKS

There is almost always at least one user who happens to be using that common password, especially seasonal passwords that combine a season name with a year.

ANALOGY

It's like trying one single key on every door in an apartment building, instead of trying a hundred keys on just one door.



3

2. AS-REP ROASTING

CONCEPT

Kerberos has a setting called "Do not require Kerberos preauthentication." If an account has this setting enabled, anyone can request that account's authentication data without ever knowing its password.

WHY IT'S DANGEROUS

What comes back is partially encrypted using the account's password. That data can then be taken offline and cracked using tools like Hashcat, far away from any monitoring.

ANALOGY

It's like someone asking a security question to reset your account password, but the system responds without first confirming they actually own the account — and that response leaves a trace that can later be analyzed to reveal the password.



4

3. KERBEROASTING

CONCEPT

Any regular domain user, not just an administrator, can request a "service ticket" for any service on the network, such as SQL Server. That ticket is encrypted using the password of the service account running that service.

WHY IT'S DANGEROUS

If the service account's password is weak or old, the ticket can be taken offline and cracked to reveal that password. Requesting the ticket is completely normal Kerberos behavior, so it rarely raises suspicion.

HOW IT DIFFERS FROM AS-REP ROASTING

AS-REP Roasting only targets accounts with a specific, rare setting disabled. Kerberoasting works against any service account with a registered SPN — which is extremely common in any Active Directory environment.



5

4. PASS-THE-HASH (PtH)

CONCEPT

You don't need the original password at all. If you have the account's NTLM hash, an encrypted representation of the password, you can use that hash directly to log in, because Windows itself authenticates using the hash rather than the plaintext password.

WHY IT'S DANGEROUS

If a hash is stolen from one machine, it may work on many other machines, especially when the same local administrator password is reused across the network.

ANALOGY

It's like having a copy of someone's fingerprint instead of their actual key — but that fingerprint alone is enough to unlock the door.



6

5. PASS-THE-TICKET (PtT)

CONCEPT

Similar to Pass-the-Hash, but instead of a hash, the attacker uses a real Kerberos ticket, either a TGT or a service ticket, stolen from an infected machine, and injects it into another session to act as that same user.

WHY IT'S DANGEROUS

The ticket is genuinely issued by the system, not forged, so it is accepted normally by anything relying on Kerberos.

ANALOGY

It's like stealing an employee's real access badge and using it to open any door that employee is authorized to open.



7

6. SILVER TICKET

CONCEPT

Here, the attacker doesn't steal an existing ticket — they forge a brand-new one from scratch. To do this, they need the password of the service account tied to one specific service.

SCOPE

The forged ticket only works against that one specific service the attacker has the secret for.

ANALOGY

It's like knowing the official stamp of one specific office in a building — you can print a fake access pass, but it only works for that one office, not the rest of the building.



8

7. GOLDEN TICKET

CONCEPT

This is the most dangerous technique on the list. Instead of compromising one service's password, the attacker obtains the secret of an account called KRBTGT — the account the entire domain uses to sign every single Kerberos ticket.

WHY IT'S SO DANGEROUS

With that secret, an attacker can forge a ticket representing any account in the domain, even Domain Admin, and that forged ticket works across every service in the entire domain, not just one.

IMPORTANT NOTE

Even if the impersonated admin account's password is changed afterward, the forged ticket still works, because it was signed using the KRBTGT secret, not the admin's own password. The only real fix is rotating the KRBTGT secret itself, and it must be rotated twice.

ANALOGY

If a Silver Ticket is the stamp of one office, a Golden Ticket is the master stamp of the entire building's owner — with it, you can forge an access pass to anywhere in the building and impersonate anyone.



9

QUICK COMPARISON TABLE

1	Password Spraying	requires guessing; impacts one account.
2	AS-REP Roasting	requires an account with a weak setting; impacts one account's password.
3	Kerberoasting	requires any regular user; impacts one service account's password.
4	Pass-the-Hash (PtH)	requires a stolen hash; impacts the same privileges as that user.
5	Pass-the-Ticket (PtT)	requires a stolen real ticket; impacts the same privileges as the ticket owner.
6	Silver Ticket	requires a service account secret; impacts one specific service only.
7	Golden Ticket	requires the KRBTGT secret; impacts the entire domain.